

Digital Policy Office

INFORMATION SECURITY

Practice Guide

for

Security Controls of Web 2.0 Application Development

Version 1.1

July 2024

© The Government of the Hong Kong Special Administrative Region
of the People's Republic of China

The contents of this document remain the property of and may not be reproduced in whole or in part without the express permission of the Government of the Hong Kong Special Administrative Region of the People's Republic of China.

COPYRIGHT NOTICE

© 2024 by the Government of the Hong Kong Special Administrative Region of the People's Republic of China

Unless otherwise indicated, the copyright in the works contained in this publication is owned by the Government of the Hong Kong Special Administrative Region of the People's Republic of China. You may generally copy and distribute these materials in any format or medium provided the following conditions are met –

- (a) the particular item has not been specifically indicated to be excluded and is therefore not to be copied or distributed;
- (b) the copying is not done for the purpose of creating copies for sale;
- (c) the materials must be reproduced accurately and must not be used in a misleading context; and
- (d) the copies shall be accompanied by the words “copied/distributed with the permission of the Government of the Hong Kong Special Administrative Region of the People's Republic of China. All rights reserved.”

If you wish to make copies for purposes other than that permitted above, you should seek permission by contacting the Digital Policy Office.

Amendment History				
Change Number	Revision Description	Pages Affected	Revision Number	Date
1	Change “Office of the Government Chief Information Officer” (or “OGCIO”) to “Digital Policy Office” (or “DPO”)		1.1	July 2024

Table of Contents

1.	Introduction.....	1
1.1	Purpose.....	1
1.2	Normative References.....	1
1.3	Terms and Convention.....	2
1.4	Contact	3
2.	Common Security Measures.....	4
2.1	Usage Policy	4
2.2	Overall System Design, Development and Maintenance.....	4
2.3	Access, Authentication and Authorisation.....	4
2.4	Data Validation	5
2.5	Vulnerability Management	5
2.6	User Awareness	6
3.	Wikis Related Security Measures.....	7
3.1	Collaborative Editing	7
3.2	Editorial Controls.....	7
3.3	Account Maintenance	7
3.4	User Awareness	7
4.	Blogs Related Security Measures	8
4.1	Privacy and Data Protection.....	8
4.2	Site Configuration	8
4.3	Monitoring and Filtering on Content	8
4.4	Usage.....	8
4.5	Policy	8
5.	Web Feeds Related Security Measures.....	9
5.1	Validation on feed content	9
5.2	Protections for Subscribers	9
6.	Social Networking Services Related Security Measures	10
6.1	Policy	10

TABLE OF CONTENTS

6.2	Privacy Settings and Controls	10
6.3	Access Control	10
6.4	Content Management	10
6.5	User Awareness	10

1. Introduction

"Web 2.0" generally refers to the second generation of web application technologies that facilitate communication, information sharing and collaboration on the Internet. Wikis, Blogs, Really Simple Syndication (RSS) and Social Networking Services (SNSs) are examples of Web 2.0 services.

1.1 Purpose

This document outlines the security measures when constructing, deploying or administrating Web 2.0 applications. It is also recommended to read this in connection with the document "Quick references on the security of web application development" which provides a comprehensive list of security principles for developing general web applications.

1.2 Normative References

The following referenced documents are indispensable for the application of this document.

- Fear of Web 2.0, ReadWriteWeb, MacManus, R., 2007
http://readwrite.com/2007/09/17/fear_of_web_20/
- Jeopardy in Web 2.0 - The Next Generation Web, OWASP, Mehta, D., n.d.
http://www.owasp.org/images/b/b6/Jeopardy_in_Web_2.0_-_The_Next_Generation_Web_Applications.pdf
- Less than 10 things you should know about Web 2.0 Security, TRUSTSTIX INC, Mysore, S., 2008
https://www.helpnetsecurity.com/dl/articles/Web2_0Security.pdf
- Position Paper - Web 2.0 Security and Privacy, Enisa, Hogben, G. et al, 2008
https://www.enisa.europa.eu/publications/copy_of_report/at_download/fullReport
- Security in a Web 2.0 environment, Titterington, G., 2007
<http://store.ovum.com/Product.asp?tnpid=67028&tnid=67028&pid=38656&cid=0>
- Top Web 2.0 Security Threats, Secure Enterprise 2.0 Forum, 2009
http://www.oerafrica.org/system/files/7705/top-web-2-0-security-threats_0.pdf?file=1&type=node&id=7705
- Web 2.0 and Security, Government of the HKSAR, 2008
<http://www.itginfo.gov.hk/content/itsecure/techcorner/article/web20.htm>

1.3 Terms and Convention

For the purposes of this document, the terms and convention given in S17, G3, and the following apply.

Abbreviation and Terms	
NA	NA

1.4 Contact

This document is produced and maintained by the Digital Policy Office (DPO). For comments or suggestions, please send to :

Email: it_security@digitalpolicy.gov.hk

Lotus Notes mail: IT Security Team/DPO/HKSARG@DPO

2. Common Security Measures

This part focuses on the common security measures when designing Web 2.0 applications:

2.1 Usage Policy

- a) Provide clear guidelines to make users aware of what information to be shared, with whom they can share it, and what not to share. Measures should be in place to moderate the posted contents where appropriate.
- b) Provide terms and conditions covering what content and activities are allowed on the site/platform. Guidelines should also be included for all participants who provide publicly accessible content.
- c) Include a prominent link to the Privacy Policy Statement whenever personal data are collected. Enforce the policies on protection of personal information or privacy, and data retention.
- d) Include disclaimers at appropriate places to specify or limit the scope of rights and obligations.

2.2 Overall System Design, Development and Maintenance

- a) Implement proper security measures including authentication and access controls, input validation, session management and error handling to avert threats that may result in unauthorised intrusion.
- b) Restrict the use of client-side scripts (e.g. defining document.domain property, using call back function) which could violate the same-origin policy and lead to Cross-Site Scripting (XSS) vulnerabilities. The same-origin policy prevents a document or script from loading at one origin getting or setting properties of a document from another origin.
- c) Deploy web application firewall, IDS / IPS system to protect the application and end users.
- d) Conduct security risk assessments before launching any new application or program releases. Regular security audits should be conducted accordingly.

2.3 Access, Authentication and Authorisation

- a) Define different levels/roles on user access, e.g. anonymous readers, posters, regulators. Apply access control to allow authorised users only.
- b) Use secure channels such as TLS/SSL based encryption wherever sensitive data such as passwords or personal data are transmitted.
- c) Avoid using 'IFrame' in Web 2.0 environment. Sandboxing features offered by the 'IFrame' HTML tag are often insufficient and allow illegitimate cross-domain communication.
- d) Protect and restrict the access to sensitive information and resources that should be accessible to specific authorised users only.
- e) Restrict the types of files allowable for upload. Uploading executable programs or scripts should be controlled.

- f) Apply appropriate control mechanism such as challenge-response mechanisms (e.g. CAPTCHA¹) to prevent submission of garbage data (also known as web spam).

2.4 Data Validation

- a) Perform data validation in both directions at the server-side to limit or prevent injection or other forms of attacks.
- b) Parse and check thoroughly data input by users for permitted formats and ranges. For instance, it should be checked for SQL injection attack on a database application, or active / dangerous scripts that may be fed to the system, e.g.
- c) active content (e.g. '<SCRIPT>')
- d) validity (e.g. alphabet in numeric field)
- e) code injection (e.g. SQL statement to database engine)
- f) Encode all XML data is a good method to prevent malicious input from exploiting vulnerability by altering the data format. Special characters like brackets, quotes, and ampersands may be interpreted as harmless character strings by the browser or application server, which may lead to attacks such as XSS or SQL injection.

2.5 Vulnerability Management

- a) Carry out rigorous vulnerability tests to identify loopholes and uncover any weakness, including command injection, XSS, Cross-Site Request Forgery (CSRF) and buffer overflow.
- b) Develop measures to detect and filter malicious content. Technologies such as XML, Asynchronous JavaScript XML (AJAX) and JavaScript Object Notation (JSON) are commonly used in Web 2.0 applications. The following table shows the common attack vectors and corresponding checking to be performed to prevent the vulnerabilities.

¹ Completely Automated Public Turing test to tell Computers and Humans Apart

Attack Vectors	Measures to Detect or Filter Malicious Content
XML poisoning	Check the SOAP envelope for suspicious content that may inject or overwrite information when parsed by SAX or DOM parser, e.g. cause a loop in the parser.
Parameter tampering (meta-characters)	Check if meta-characters like single quote ('), double quote ("), ampersand (&), percentage (%) and dollar signs (\$) are used that may break application logic.
Parameter tampering (data type)	Check if different data types are injected, e.g. integer instead of string on a name field.
Parameter tampering (abnormal values)	Check for out-of-boundary values.
SQL injection with SOAP manipulation	Check if single quote ('), double quote ("), hyphen (-), query with (OR 1=1) are injected into the SQL query.
XPATH injection	Check if slash (/), double slash (//), dot (.), double dot (..), @, =, < and > or query with (OR 1=1) are used to traverse through nodes of XML documents.
Directory traversal and file system access through SOAP	Check if directory traversal (../..) is used to fetch other files from parent directories.
Operating system command execution using vulnerable web services	Check if command structure with pipe () character is used to trigger execution of next command.
SOAP message brute force	Check for the use of dictionary words or repetitive retries of login.
Session hijacking with web services	Check if weak algorithm is being used for cookie in which attackers may hijack the session by guessing the cookie.

2.6 User Awareness

- Remind users that the content submitted may persist in caches, web search engines, backend data stores, archives, etc. They should be very careful before posting any information, in particular sensitive or personal data.
- Remind users never to disclose their username, password or personal data in any circumstances.
- Remind users the possibility of phishing attack and not to follow the links provided by anonymous users or other Web 2.0 applications.

Remind users to interpret TLS/SSL signs and errors in browsers. For example, the meaning of expired certificate errors, certificate does not match with the website domain, etc.

3. Wikis Related Security Measures

Wikis are collaborative knowledge bases compiling content contributed by anonymous visitors and registered editors. Wikis encourage information sharing but there are also challenges on information security and content integrity. The following measures can be applied to protect the platform and ensure its integrity.

3.1 Collaborative Editing

- a) State and enforce that articles must conform to standards ensuring the objectivity, factuality and relevance preventing users from creating spurious articles, adding irrelevant text not complying with the terms of service.
- b) Review all editions by screening and processing them thoroughly in a hierarchy by editors or regulators.
- c) Implement autonomous agents or scripts that can reverse edit or provide notifications to editors or regulators when edition is made in order to filter improper contents or malicious codes.

3.2 Editorial Controls

- a) Implement controls to restrict postings to legitimate and authorised areas only. Proper user authentication and access control should also be applied to ensure the authenticity.

3.3 Account Maintenance

- a) Separate accounts for different roles of users such as editors and administrators.

3.4 User Awareness

- a) Remind users to respect copyrights when posting contents.

4. Blogs Related Security Measures

Blogs are places with regular entries of commentary, descriptions of events in the form of text, graphics, audios and/or videos. Users are free to post contents on these sites. The following measures can be applied to mitigate the potential risks and protect user data.

4.1 Privacy and Data Protection

- a) Allow bloggers to set and control information only available to limited users according to pre-set groups or rules with granular access, e.g. able to only read or respond to blog message.
- b) Perform data backup and archive regularly.

4.2 Site Configuration

- a) Use database to store all blog contents, and grant appropriate access to bloggers.
- b) Use strong and different passwords for database administrators and blog site administrator.
- c) Apply IP address filtering or multi-factor authentication to safeguard the access to administrator accounts.
- d) Ensure access to all configuration files and directories are limited to site administrator only.
- e) Ensure users have limited rights to update pages and will not be able to alter contents authored by others.

4.3 Monitoring and Filtering on Content

- a) Implement monitoring and filtering controls for all blog content, paying special attention on the followings:
 - Private personal information
 - Departmental sensitive or proprietary information
 - Abuse or illegal activities
 - Non-meaningful blog comments with URL included that may be generated by virus/trojan infected users
 - Pornographic content or foul language
- b) Implement measures or controls to remove improper content.

4.4 Usage

- a) Prepare and publish acceptable usage policies.
- b) Consider to create a blacklist of specific users/readers who have violated the acceptable usage policies and restrict their access rights accordingly.
- c) Grant access rights only to authorised users for sensitive and restricted content.

4.5 Policy

- a) Enforce the usage policies with regular monitoring.
- b) Establish complaint channels / mechanism to receive reports of improper content or abuse.

5. Web Feeds Related Security Measures

A web feed (or news feed) is a data format which is used to publish frequently updated content. The two main web feed formats are RSS and Atom. The following security controls should be considered when publishing or using web feeds.

5.1 Validation on feed content

- a) Only trust data feeds from reputable sources.
- b) Deploy preventive measures such as white-listing of possible HTML tags when providing web feeds.
- c) Check the feed content originating from external sources for suspicious codes or active content such as `<script>`. Information from various feeds, blogs and search engines should not be directly fed to user's browser without any checking.
- d) Use feed validation service² to check the syntax of web feeds.
- e) Discard excess characters such as `'<'`, `'>'`, `'<'` and `'>'` at server-side before pushing the data to users. RSS injection is a technique used by attackers to inject literal JavaScript into feeds to lodge attacks on the client browser that may lead to browser cookies being stolen or arbitrary code execution.
- f) Inspect the header content to validate and get feed type version information. When processing feeds with MIME-types, check for the XML well-formedness and XML schema.

5.2 Protections for Subscribers

- a) Suggest users to enable further protection by disabling script, applet and plug-in execution with the trade-off that the functionality may be limited.

² For example, <http://validator.w3.org/feed/>, a free service provided by W3C to check the syntax of Atom or RSS feeds.

6. Social Networking Services Related Security Measures

Social networking services (SNSs) focus on building online communities of people who share interests and/or activities. It allows users to create their own profiles and grant rights to others for accessing their information or latest status. Below are some measures to enhance the security controls.

6.1 Policy

- a) Establish policies to ensure sensitive data and/or user information will not be disclosed in SNSs. Remind users not to reveal any information that may cause embarrassment or discredit to Government when engaged in SNSs.
- b) Develop data retention policies to purge obsolete information and minimise data exposure. Remind users that once information is posted, it may be grasped by search engines and difficult to be completely removed from the Internet.

6.2 Privacy Settings and Controls

- a) Allow users to set restrictions on certain content with different access rights granted to users or groups based on their relationships.
- b) Remind users to avoid placing too much personal information to SNSs.
- c) Restrict web crawling to the contents which are not supposed to be searched or archived by public search engines.

6.3 Access Control

- a) Consider to deploy relationship-based access control to model the interpersonal relationship in the real world. The data owner can build up a table of selected users that maps the access rights on the data with the relationships.
- b) Remind users to use strong authentication where appropriate and not to use the same password for various social networking sites.
- c) Ensure user profiles cannot be accessed before successful authentication.

6.4 Content Management

- a) Filter out spam or suspicious content using control measures such as automatic filtering tools.
- b) Provide channels for users to report problems on content or abuse, e.g. inappropriate content posted by other users.

6.5 User Awareness

- a) Remind users the impact of personal or sensitive information leakage from any posting on SNSs.
- b) Remind users not to follow any link sent by strangers or suspicious sources, nor run any applications or download programs from un-trusted sources.